

# Setnayan — Records of Processing Activities (RoPA) / Data Inventory

**DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization and NPC filing; not yet adopted. · 2026-07-05**

The accountability record RA 10173 (Data Privacy Act of 2012) and its IRR require a Personal Information Controller (PIC) to maintain: a register of the Data Processing Systems (DPS) it operates. Each row below is **one DPS**. Sourced from `01_Contracts/Setnayan_Privacy_and_Security_Policy.md` (§1 data collected, §3 where data lives, §4 retention, §6 consent, §10 sub-processors) and `03_Strategy/Compliance_Pack_PersonGraph_DRAFT_2026-07-05.md`. Facts not established in those sources are marked `[TO CONFIRM]` — none invented.

## 0. Controller & governance identification

| Field                                                        | Value                                                                                           |
|--------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| Personal Information Controller (PIC)                        | SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II   |
| DTI Business Name Registration                               | BN 8297508 · valid 25 Jun 2026 – 25 Jun 2031                                                    |
| Brand / trade name                                           | Setnayan                                                                                        |
| Public domains                                               | setnayan.com · setnayan.ph                                                                      |
| Registered business address                                  | [TO CONFIRM]                                                                                    |
| Total headcount / employees                                  | [TO CONFIRM]                                                                                    |
| NPC registration number (if already registered)              | [TO CONFIRM]                                                                                    |
| Data Protection Officer (DPO)                                | Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com (registered with the NPC per policy §9) |
| DPO response SLA                                             | 15 business days (non-urgent); immediate for breach notifications                               |
| Breach notification                                          | NPC + affected users within 72 hours of confirmation (policy §8)                                |
| Estimated data-subject counts (customers / vendors / guests) | [TO CONFIRM]                                                                                    |

### Shared infrastructure (applies across DPS's unless a row narrows it)

| Layer                     | Provider | Location            | Role      |
|---------------------------|----------|---------------------|-----------|
| Web / application hosting | Vercel   | [TO CONFIRM] (edge) | Processor |

|                                                                         |                                             |                                                                               |                                                                                                                                                                      |
|-------------------------------------------------------------------------|---------------------------------------------|-------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Primary database (PII + transactional + <b>biometric face vectors</b> ) | Supabase / Postgres                         | <b>Singapore</b>                                                              | Processor · AES-256 at rest · RLS. <b>Face vectors live HERE</b> , as JSONB columns (guest_face_enrollments.face_vectors, user_face_profiles) — corrected 2026-07-31 |
| Media (photos / video / <b>source selfie images</b> )                   | Cloudflare R2                               | <b>Asia-Pacific (APAC)</b> ■ confirmed in the Cloudflare dashboard 2026-08-01 | Processor · signed-URL access only. <b>Does NOT hold face vectors</b> — corrected 2026-07-31                                                                         |
| Transactional email                                                     | Resend                                      | [TO CONFIRM] (US-based likely)                                                | Processor                                                                                                                                                            |
| Vendor ID verification                                                  | Persona / Veriff / Onfido                   | <b>US</b>                                                                     | Processor (batch-call, no ongoing storage)                                                                                                                           |
| AI text/contract analysis                                               | Anthropic (Claude) · OpenAI (V1.5 fallback) | <b>US</b>                                                                     | Processor · zero-retention API mode (Anthropic)                                                                                                                      |
| Music generation                                                        | Suno                                        | [TO CONFIRM]                                                                  | Processor — <b>no PII processed</b>                                                                                                                                  |

**Cross-border baseline:** routine operation crosses the SG↔PH border; encrypted in transit (TLS 1.3), governed by Cloudflare's and Supabase's PH-compliant DPAs, subject to NPC oversight (policy §10). US sub-processors are bound by Standard Contractual Clauses (SCCs) or equivalent (policy §10).

## 1. Records of Processing Activities — one record per Data Processing System

Legend — Legal basis per RA 10173 §12 (personal info) / §13 (sensitive personal info): **Contract** = §12(b) performance of contract; **Consent** = §12(a)/§13(a); **Legitimate interest** = §12(f); **Legal obligation** = §12(c)/§13(b)/§13(f). SPI = Sensitive Personal Information per RA 10173 §3(l).

### DPS-01 · Customer / Couple Account & Event Planning

| Field                              | Detail                                                                                                                                                                                                                              |
|------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Purpose</b>                     | Provide the contracted planning platform: account, event setup, vendor matching (Guided + DIY), seating, save-the-date, in-app services                                                                                             |
| <b>Legal basis</b>                 | Contract (§12(b)) — service delivery; Consent (§12(a)) for marketing-sample opt-in (policy §6.2)                                                                                                                                    |
| <b>Data subjects</b>               | Customers (couples / organizers)                                                                                                                                                                                                    |
| <b>Personal data categories</b>    | Full name, mobile, email, optional profile photo; event data (date, venue, target pax, role); behavioral/in-app activity, Guided-mode decisions, search queries; uploaded content (Save-the-Date photos, invitation customizations) |
| <b>SPI?</b>                        | <b>N</b> (no SPI in the core account record)                                                                                                                                                                                        |
| <b>Recipients / sub-processors</b> | Supabase (DB), Vercel (hosting), Cloudflare R2 (content); Setnayan Team on mediation only                                                                                                                                           |

|                              |                                                                                                                                                    |
|------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Cross-border transfer</b> | SG (Supabase); APAC (R2)                                                                                                                           |
| <b>Retention</b>             | Account profile: active + 30-day grace on deletion, then purge.<br>Event data: 5 years post-event, auto-purge T+5y; earlier on request (policy §4) |
| <b>Security measures</b>     | AES-256 at rest; RLS per-user isolation; TLS 1.3; bcrypt passwords; optional 2FA; signed URLs for media                                            |
| <b>Risk level</b>            | <b>Medium</b>                                                                                                                                      |

## DPS-02 · Vendor Account, Profile & Verification

| Field                              | Detail                                                                                                                                                                                                                                                                                                                                                                  |
|------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Purpose</b>                     | Vendor onboarding, business profile, and the 12-document identity/business verification checklist (policy §3.4)                                                                                                                                                                                                                                                         |
| <b>Legal basis</b>                 | Contract (§12(b)); Legitimate interest (§12(f)) — DTI lookup, portfolio reverse-image, reference calls; <b>Legal obligation</b> (§13(f) / §12(c)) — AMLC sanctions/PEP screening per PH AMLA; Consent captured at registration                                                                                                                                          |
| <b>Data subjects</b>               | Vendors (business owners / primary representatives)                                                                                                                                                                                                                                                                                                                     |
| <b>Personal data categories</b>    | Business identity (DTI Business Name Cert, BIR Form 2303, Mayor's Permit, business address, name+slug); service profile; financial (bank/e-wallet payout account, transaction history); behavioral (response times, conversion)                                                                                                                                         |
| <b>SPI?</b>                        | <b>Y</b> — <b>government-issued ID</b> of the primary representative (RA 10173 §3(l) SPI); selfie + ID liveness video (biometric-adjacent). DTI/BIR/tax documents are legally-mandated records                                                                                                                                                                          |
| <b>Recipients / sub-processors</b> | Persona / Veriff / Onfido (ID + liveness); AMLC API / ComplyAdvantage (sanctions/PEP); DTI Database (BN validation); Supabase; Cloudflare R2 bucket <code>setnayan-vendor-verification</code> (Verification Handler role only)                                                                                                                                          |
| <b>Cross-border transfer</b>       | US (Persona/Veriff/Onfido); UK (ComplyAdvantage); PH (AMLC, DTI); SG (Supabase); APAC (R2)                                                                                                                                                                                                                                                                              |
| <b>Retention</b>                   | Raw uploads (ID, selfie+liveness, bank micro-deposit, portfolio): 90 days hot, purged after approve/reject unless audit hold. Verification audit trail (Persona/AMLC results + admin rationale): 90 days hot + <b>7 years cold</b> (BIR §235 + AMLC AML/CTF). DTI/BIR 2303/Mayor's Permit: 90 days hot + <b>7 years cold</b> . Transaction history: 5 years (policy §4) |
| <b>Security measures</b>           | Extra-restricted R2 bucket (single admin role); batch-call verification (no ongoing sub-processor storage); AES-256; RLS; audit log on all admin decisions                                                                                                                                                                                                              |
| <b>Risk level</b>                  | <b>High</b> (SPI: gov ID + biometric liveness)                                                                                                                                                                                                                                                                                                                          |

## DPS-03 · Guest List & RSVP

| Field                       | Detail                                                                                                                                                                                                            |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Purpose                     | Manage the couple's guest list, RSVP status, roles, table assignment, and special requests                                                                                                                        |
| Legal basis                 | Contract (§12(b)) — organizer's event service; Consent (§12(a)) for guest-provided data / photo consent at RSVP (policy §6.1)                                                                                     |
| Data subjects               | Guests                                                                                                                                                                                                            |
| Personal data categories    | Full name, mobile, email, optional profile photo; event linkage + role (principal/secondary sponsor, family, friend), RSVP status, table assignment; behavioral (reels built, re-shares)                          |
| SPI?                        | <b>Potentially Y</b> — dietary restrictions / special-needs data collected at RSVP may reveal <b>health or religious</b> SPI (RA 10173 §3(l)). [TO CONFIRM] exact special-data fields captured in the RSVP schema |
| Recipients / sub-processors | Supabase; event organizer (couple); coordinator within join-permission scope                                                                                                                                      |
| Cross-border transfer       | SG (Supabase)                                                                                                                                                                                                     |
| Retention                   | Aligned with event retention: 5 years post-event; deletion cascades on guest account deletion (subject to shared-gallery organizer-consent exception, policy §4)                                                  |
| Security measures           | RLS event-scoping; TLS 1.3; guest opt-out toggles; AES-256                                                                                                                                                        |
| Risk level                  | <b>Medium</b> (High if dietary/health SPI confirmed)                                                                                                                                                              |

#### DPS-04 · Face Vectors / Auto-Tagging (per-event, consented)

| Field                    | Detail                                                                                                                                                      |
|--------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Purpose                  | Auto-tag guests in an event's photo gallery via face matching (couple-scoped only)                                                                          |
| Legal basis              | Consent (§13(a)) — guest opts in by uploading RSVP profile photo for this purpose; revocable via "Delete my face data" / Photo Consent toggle (policy §6.1) |
| Data subjects            | Guests                                                                                                                                                      |
| Personal data categories | 128-dimension <b>face vectors</b> derived from RSVP photo + optional portal upload + on-the-day check-in kiosk                                              |
| SPI?                     | <b>Y — BIOMETRIC</b> data (RA 10173 §3(l)). Highest-sensitivity category in the platform                                                                    |

|                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Recipients / sub-processors | <b>Supabase (Singapore) — the vectors themselves</b> , as JSONB in <code>guest_face_enrollments.face_vector</code> + <code>user_face_profiles</code> ; Cloudflare R2 (APAC) holds only the <b>source selfie image</b> ( <code>asset_url</code> ). ■ <b>[TO CONFIRM]</b><br><b>RESOLVED 2026-07-31 from shipped code: there is NO third-party matching engine.</b> Embedding runs <b>on-device / in-browser</b> ( <code>face-api.js</code> / <code>MediaPipe</code> , <code>lib/face-embed.ts</code> ) and matching runs against our own Postgres rows — <b>no face data is sent to any AI sub-processor</b> . (Prior text placed a "per-event encrypted vector index" on R2; no such index was ever built.) |
| Cross-border transfer       | <b>Singapore</b> (Supabase — the vectors) + <b>APAC</b> (R2 — the source selfie images). Corrected 2026-07-31; both outside PH, so the § cross-border conclusion is unchanged, but the <i>location of the biometric SPI</i> is now stated accurately.                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Retention                   | Per-event lifetime + 5 years; auto-purge with event data. Guest revocation propagates within the next 5-minute refresh cycle (policy §1.4, §4)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Security measures           | <b>Per-event scoped — vectors never reused across events</b> ; encrypted at rest; no cross-event face recognition (design lock, Person Graph DPIA #6); confidence-gated auto-tag                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Risk level                  | <b>High</b> (biometric SPI)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |

## DPS-05 · Papic / Photo & Video Capture & Delivery

| Field                                                          | Detail                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|----------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Purpose                                                        | Capture, store, tag, and deliver event photos/clips to couples and guests; Personal Reel rendering                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Legal basis                                                    | Contract (§12(b)) — paid capture/delivery service; Consent (§6.1) for likeness/photo participation; opt-out → face-blur                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Data subjects                                                  | Guests, customers (couples); incidental non-account attendees appearing in media                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Capture sources <i>(added 2026-08-02 — closes DPO gate 0d)</i> | Three, and the RoPA previously named none of them explicitly: (1) <b>designated paparazzi seats</b> (a friend/family member claims a seat and shoots); (2) <b>the guests' OWN PHONES</b> — a guest buying or being granted Papic captures on their personal device, which is the dominant source now that Papic Pool sells as a shared-shot pool; (3) a <b>paired DSLR</b> bridged through a paired phone. Source (2) is the one this amendment exists to state: the media in this system is largely captured by ordinary attendees on their own handsets, not by an operator Setnayan or the couple controls |
| Personal data categories                                       | Photos and video clips; likeness; capture metadata ( <code>captured_at</code> , geo when available, device model, paired camera brand/model); tag associations                                                                                                                                                                                                                                                                                                                                                                                                                                                |

|                                                                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|--------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Delivery mechanism</b> <i>(added 2026-08-02 — closes DPO gate 0d)</i> | Media is <b>sorted to a guest by face matching</b> where that guest consented to it (DPS-04), and delivered to their personal gallery. So a guest's likeness, captured on a <i>stranger's</i> phone, reaches them through an automated biometric match. The untagged-still-delivered rule means the couple receives everything regardless                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| <b>SPI?</b>                                                              | <b>N</b> in the general case (images of persons are personal info, not per-se SPI), but images can incidentally reveal SPI (health, religion). Treat as elevated                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| <b>Recipients / sub-processors</b>                                       | Cloudflare R2 (originals, signed-URL only); Supabase (tags/metadata); hierarchical read: organizer / coordinator / guest (tagged + global) / vendor (booking-relevant)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| <b>Cross-border transfer</b>                                             | APAC (R2)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| <b>Retention</b>                                                         | Full-resolution ORIGINAL: the later of 6 months from the event's first capture and 3 months after the event ENDS (the celebration's last day: <code>event_end_date</code> where the event spans several days, else <code>event_date</code> — owner 2026-08-10), then <b>replaced by</b> a compressed web copy. <b>Compressed web copy: free for 5 years; past 5 years, continuing to store it becomes a paid option whose price is not yet set (owner 2026-08-07, superseding the 2026-07-10 "free forever" lock).</b> ■ Nothing is deleted at 5 years — <b>the owner set a price REVIEW, not a deletion, and the consequence of declining to pay is NOT decided. Do not build or document a 5-year purge.</b> No scheduled deletion at any point. <b>No photo is ever deleted on a schedule.</b> Disposal occurs only on organizer removal, a validated erasure request, or account deletion. Originals synced to the couple's own Google Drive are theirs permanently and are never touched. Geo stripped on outbound shares; the original on R2 retains it (policy §4). ■ <b>CORRECTED 2026-08-07.</b> This row previously declared a <b>5-year hard limit</b> with 90-day-hot/5-year-cold tiering. That tiering was never built, no R2 lifecycle rule exists, and the compressed copy is kept indefinitely — so the row committed us, in a filing, to destroying photos we in fact keep. Declaring a purge that never happens is the more dangerous direction of drift: a commitment to the regulator broken every day. |
| <b>Security measures</b>                                                 | Signed URLs (5-min for sensitive media); no public reads; NSFW filter on-by-default (non-disableable); untagged-still-delivered; opt-out face-blur; couple review window before public unlock                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| <b>Risk level</b>                                                        | <b>Medium–High</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |

## DPS-06 · Person Graph — Connections, Life Stories & Trusted-Circle (adults-only)

| Field          | Detail                                                                                                                                                         |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Purpose</b> | Durable person node; mutually-confirmed relationship connections; per-person life-story references; aggregate trusted-circle vendor signal (Person Graph pack) |

|                             |                                                                                                                                                                                                                                                    |
|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Legal basis                 | Consent (§12(a)) — <b>mutual, opt-in confirmation</b> required for every edge; life stories rely on existing RSVP photo consent                                                                                                                    |
| Data subjects               | Customers, guests ( <b>adults only</b> — minors NOT processed)                                                                                                                                                                                     |
| Personal data categories    | Person node (name, optional photo, events participated); first-degree connection edges (type + confirmed/pending state); life-story items = <b>references (pointers), not copies</b> ; trusted-circle signal = <b>computed on read, not stored</b> |
| SPI?                        | <b>Potentially Y</b> — relationship data can infer SPI (e.g., civil status, family/religious ties). Mitigated: extended kin <b>derived not stored</b> ; min-N ≥5 on aggregates                                                                     |
| Recipients / sub-processors | Supabase (edges + references); no third-party sharing; connections never broadcast/browsable                                                                                                                                                       |
| Cross-border transfer       | SG (Supabase)                                                                                                                                                                                                                                      |
| Retention                   | Edges + references follow event/account retention (policy §4 / Compliance Pack §3); declined/hidden/opted-out suppressed immediately; reference dies with source media; trusted-circle not stored                                                  |
| Security measures           | Mutual-confirmation gate; name-only + confirmed-only cross-person visibility; participant-scoped deny-by-default RLS; no "people you may know"; <b>no cross-event face recognition</b> ; DPIA completed (Compliance Pack §2, residual Low)         |
| Risk level                  | <b>Medium</b> — Status: <b>DRAFT, live behind flags; pending DPO/counsel sign-off</b> . Minors/legacy (Phase 3) counsel-first, DPIA scoped-not-complete, <b>not processed</b>                                                                      |

## DPS-07 · In-App Communications / Chat (0019)

| Field                       | Detail                                                                                                                                                            |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Purpose                     | Text chat between couples ↔ vendors ↔ coordinators; document/sheet/PDF/image sharing on threads                                                                   |
| Legal basis                 | Contract (§12(b)) — coordination is core service                                                                                                                  |
| Data subjects               | Customers, vendors, coordinators                                                                                                                                  |
| Personal data categories    | Chat message content; attached files (doc/sheet/PDF/image); pasted external meeting links (plain text). Vendor identity masked (company logo, not personal photo) |
| SPI?                        | <b>N</b> structurally, but free-text/attachments may contain SPI — treat as elevated                                                                              |
| Recipients / sub-processors | Supabase Realtime (ephemeral) + Postgres (history); Cloudflare R2 thread-files bucket. <b>Video meetings RETIRED 2026-05-16 — no video data stored</b>            |
| Cross-border transfer       | SG (Supabase); APAC (R2)                                                                                                                                          |

|                          |                                                                                                              |
|--------------------------|--------------------------------------------------------------------------------------------------------------|
| <b>Retention</b>         | Messages: 5 years (aligned to event retention). Pasted meeting links follow parent message (policy §3.3, §4) |
| <b>Security measures</b> | RLS thread-scoping; per-thread coordinator join permission; vendor-identity masking; TLS 1.3; AES-256        |
| <b>Risk level</b>        | <b>Medium</b>                                                                                                |

#### DPS-08 · Payments & Reconciliation (apply-then-pay)

| Field                              | Detail                                                                                                                                                                                                                                    |
|------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Purpose</b>                     | Process PHP-direct service orders: BDO/GCash apply-then-pay, reference codes, manual reconciliation of proof-of-payment against orders                                                                                                    |
| <b>Legal basis</b>                 | Contract (§12(b)); <b>Legal obligation</b> (§12(c)) — PH tax/BIR record retention                                                                                                                                                         |
| <b>Data subjects</b>               | Customers, vendors                                                                                                                                                                                                                        |
| <b>Personal data categories</b>    | Payment receipts, transaction references, <b>partial</b> bank/e-wallet details for receipts/refunds; payment-proof screenshots; reconciliation inbox messages. <b>No complete card numbers, CVVs, or full bank account numbers stored</b> |
| <b>SPI?</b>                        | <b>N</b>                                                                                                                                                                                                                                  |
| <b>Recipients / sub-processors</b> | Supabase (payments, service_orders, payment_inbox_messages); Setnayan Team (manual reconciliation); Maya Business (V1.5+ gateway [TO CONFIRM] not active)                                                                                 |
| <b>Cross-border transfer</b>       | SG (Supabase)                                                                                                                                                                                                                             |
| <b>Retention</b>                   | Transaction/receipt records: 5 years (tax compliance). Pending orders expire 7 days (policy §4, CLAUDE.md)                                                                                                                                |
| <b>Security measures</b>           | No card/full-account storage; two-admin approval for refunds >■10K; append-only audit log; RLS; reference codes 8-char Crockford                                                                                                          |
| <b>Risk level</b>                  | <b>Medium</b>                                                                                                                                                                                                                             |

#### DPS-09 · In-App Behavioral / Product Analytics

| Field                | Detail                                                                                                                                                |
|----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Purpose</b>       | Platform analytics for Setnayan admins (aggregated); platform improvement + ML model training (anonymized)                                            |
| <b>Legal basis</b>   | Legitimate interest (§12(f)) for aggregated operational analytics; Consent (§12(a)) for the secondary anonymized-training purpose (policy §2.1, §2.2) |
| <b>Data subjects</b> | Customers, vendors, guests                                                                                                                            |



|                                    |                                                                                                                                                                                                                           |
|------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Personal data categories</b>    | In-app activity, surfaces visited, services purchased, vendor interactions, search queries, response/conversion metrics.<br><b>Aggregated — never individually identified to admins outside dispute-mediation context</b> |
| <b>SPI?</b>                        | <b>N</b>                                                                                                                                                                                                                  |
| <b>Recipients / sub-processors</b> | Supabase; PostHog [TO CONFIRM] (referenced in repo/iteration 0035; not named in this policy) — no PII per observability design                                                                                            |
| <b>Cross-border transfer</b>       | SG (Supabase); PostHog host [TO CONFIRM]                                                                                                                                                                                  |
| <b>Retention</b>                   | Anonymized aggregate: indefinite (no PII). Underlying behavioral rows follow account/event retention (policy §4)                                                                                                          |
| <b>Security measures</b>           | Aggregation + de-identification for admin views; no PII in logs; opt-out toggle (per observability design) [TO CONFIRM]                                                                                                   |
| <b>Risk level</b>                  | <b>Low–Medium</b>                                                                                                                                                                                                         |

#### DPS-10 · Email Notifications (Resend)

| Field                              | Detail                                                                                                                                                                   |
|------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Purpose</b>                     | Transactional + milestone email: payment instructions/confirmation, refunds, vendor messages/status, RSVP received, wedding-day reminder, save-the-date, security alerts |
| <b>Legal basis</b>                 | Contract (§12(b)) for transactional mail; Consent (§12(a)) for promotional/marketing mail (revocable; RFC 8058 one-click unsubscribe)                                    |
| <b>Data subjects</b>               | Customers, vendors, guests                                                                                                                                               |
| <b>Personal data categories</b>    | Email address, recipient name, event/order context embedded in the message                                                                                               |
| <b>SPI?</b>                        | <b>N</b>                                                                                                                                                                 |
| <b>Recipients / sub-processors</b> | Resend (delivery); SendGrid fallback [TO CONFIRM]                                                                                                                        |
| <b>Cross-border transfer</b>       | US-based email provider likely [TO CONFIRM] (Resend jurisdiction)                                                                                                        |
| <b>Retention</b>                   | Follows the underlying record; delivery logs [TO CONFIRM] retention at provider                                                                                          |
| <b>Security measures</b>           | TLS in transit; one-click unsubscribe; RA 10173 + CAN-SPAM compliant templates                                                                                           |
| <b>Risk level</b>                  | <b>Low</b>                                                                                                                                                               |

#### DPS-11 · Marketing Site / Cookies & Consent

| Field | Detail |
|-------|--------|
|-------|--------|

|                                    |                                                                                                                                                               |
|------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Purpose</b>                     | Public marketing site (setnayan.com); analytics/consent management on public surfaces                                                                         |
| <b>Legal basis</b>                 | Legitimate interest (§12(f)) for essential/first-party operation; <b>Consent</b> (§12(a)) for analytics/advertising cookies                                   |
| <b>Data subjects</b>               | Website visitors (prospective customers/vendors), guests                                                                                                      |
| <b>Personal data categories</b>    | Cookie/consent state, IP, user-agent (policy acceptance is logged with timestamp + IP + user-agent), first-party analytics identifiers                        |
| <b>SPI?</b>                        | <b>N</b>                                                                                                                                                      |
| <b>Recipients / sub-processors</b> | Vercel (hosting); analytics processor [TO CONFIRM]. <b>Note:</b> third-party display ads (AdSense) were <b>RETIRED 2026-05-19</b> — no third-party ad cookies |
| <b>Cross-border transfer</b>       | [TO CONFIRM] (edge/analytics host)                                                                                                                            |
| <b>Retention</b>                   | Consent state persistence [TO CONFIRM] (design referenced 12-month persistence); policy-acceptance log per user retained with account                         |
| <b>Security measures</b>           | First-party cookie model; consent categories (essential / analytics / advertising); TLS 1.3; HSTS; CSP                                                        |
| <b>Risk level</b>                  | <b>Low</b>                                                                                                                                                    |

#### DPS-12 · Anti-Fraud & Trust Integrity (identity clustering · fraud scoring · enforcement)

| Field                | Detail                                                                                                                                                                                                                                                                                                                                                                                                        |
|----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Purpose</b>       | Protect marketplace trust signals from manipulation: cluster likely-same-person/household accounts by shared strong signals; de-duplicate vendor review/rating/booking stats per cluster with arm's-length exclusion; score per-vendor fraud anomalies; two-stage enforcement (reversible auto-suspend + human four-eyes wipe/ban). Spec <a href="#">03_Strategy/Anti_Fraud_Trust_Integrity_2026-07-05.md</a> |
| <b>Legal basis</b>   | <b>Legitimate interest (§12(f))</b> — fraud prevention / marketplace integrity. <b>Requires</b> a documented legitimate-interest balancing + <b>disclosure</b> (both outstanding — DPIA R-08 §6). Automated-suspension effect engages §16(c) (right to object) + §34 (automated processing) [TO CONFIRM] counsel                                                                                              |
| <b>Data subjects</b> | Couples / guests (whose device/address/payment signals are clustered — <b>they never see cluster membership</b> ) + vendors (scored, and subject to auto-suspend / ban)                                                                                                                                                                                                                                       |

|                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|-----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Personal data categories    | <b>Repurposed inputs (no new collection):</b> device fingerprint ( <code>user_devices.device_hash</code> ), normalized home address ( <code>users.address_normalized</code> ), payment-sender identity ( <code>payments.reference_number</code> →paying user). <b>Derived:</b> <code>identity_cluster_id</code> ; per-vendor fraud signals + 0–100 scores with <b>non-PII</b> evidence (counts/ratios/opaque labels); enforcement state + append-only audit. <b>IP deliberately NOT captured</b> |
| SPI?                        | <b>N</b> — inputs are personal information, not §3(l) SPI. Elevated because it is <b>involuntary profiling with an automated decision that has a significant effect</b> (vendor livelihood)                                                                                                                                                                                                                                                                                                      |
| Recipients / sub-processors | Supabase (Postgres, Singapore) only — no third-party/AI sub-processor. <b>Service-role / admin ONLY</b> ( <code>REVOKE ALL FROM anon, authenticated + is_admin()</code> RLS at CREATE); Setnayan admins via <code>/admin/fraud</code> + two-admin approval gate                                                                                                                                                                                                                                  |
| Cross-border transfer       | SG (Supabase)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Retention                   | <code>identity_clusters / vendor_fraud_scores</code> = recomputed matviews (no history). <code>fraud_signals + fraud_enforcement_audit</code> persist — <b>explicit retention rule not yet defined [TO CONFIRM]</b> . Signal inputs follow their source systems (device/address = account retention; payment = 5-yr tax, DPS-08)                                                                                                                                                                 |
| Security measures           | Service-role/admin-only + deny-by-default RLS at CREATE; non-PII evidence; reversible auto-suspend at high threshold (score ≥90); <b>irreversible ban never automated</b> — four-eyes gate + typed confirmation; append-only audit; help-center appeal path; AES-256; TLS 1.3                                                                                                                                                                                                                    |
| Risk level                  | <b>High — Status: LIVE in production since 2026-07-07, ahead of counsel sign-off (owner-elected).</b> DPIA R-08 drafted ( <code>08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md</code> ); Privacy Policy Anti-Fraud disclosure + LIA + formal contest path outstanding                                                                                                                                                                                                                           |

### DPS-13 · Vendor AI Assistant — automated replies + business deep-search (0022)

| Field   | Detail                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Purpose | The paid Vendor AI add-on, two capabilities: <b>(a) Auto-reply</b> — reads a couple's inbound messages + Event Brief (event date, guest count, budget-per-head, venue) in that couple↔vendor thread and drafts/auto-sends replies (and, if the vendor allows, accepts a booking) on the vendor's behalf, shown to the couple labelled "■ AI auto-reply"; <b>(b) Deep Search</b> — runs AI web-research over the <b>vendor's own</b> business across public sources (own website, directories, review sites) and stores a structured business dossier ( <code>vendor_web_dossiers</code> ) the vendor reviews to auto-fill its profile. Both are gated behind the <code>/admin/data-privacy</code> controls <code>vendor_ai_autoreply</code> + <code>vendor_deep_search</code> (fail-closed until DPO-activated) |

|                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Legal basis</b>                 | <b>Contract (§12(b))</b> — the vendor's paid add-on operating on the vendor's own shop; <b>Consent (§12(a))</b> — the couple's own act of messaging that vendor grounds the auto-reply reading their thread. Auto-reply is <b>automated processing (§34)</b> with a standing "■ AI auto-reply" label and a §16(c) object path (every message still reaches the vendor). Deep Search of already-public third-party content relies on <b>legitimate interest (§12(f))</b> , minimised to a business summary with a 180-day retention limit [TO CONFIRM] counsel |
| <b>Data subjects</b>               | Couples (inbound message text + Event Brief the auto-reply reads) + vendors (own business researched, dossier stored) + incidental third parties named on public web pages (Deep Search, e.g. a reviewer's public name)                                                                                                                                                                                                                                                                                                                                       |
| <b>Personal data categories</b>    | <b>Auto-reply:</b> couple inbound chat text + structured Event Brief fields (date, pax, budget band, venue) + the vendor's own package/pricing config; generated reply text. <b>Deep Search:</b> the vendor's own public business info (name, contact, services, review-derived facts) → <b>vendor_web_dossiers</b> . <b>Never</b> consumes SPI, face vectors, religion/faith, or the guest list                                                                                                                                                              |
| <b>SPI?</b>                        | <b>N</b> — no SPI; biometric, faith, and guest-PII consumption are explicitly carved out                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| <b>Recipients / sub-processors</b> | Supabase (Postgres, Singapore); <b>Anthropic web_search (US, Deep Search only)</b> — zero-retention API mode. <b>Single-tenant isolation:</b> a vendor's assistant reads only that vendor's own threads/business, never across vendors or across the couple's events                                                                                                                                                                                                                                                                                          |
| <b>Cross-border transfer</b>       | SG (Supabase); <b>US (Anthropic — Deep Search only)</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <b>Retention</b>                   | Deep Search dossier <b>vendor_web_dossiers</b> — rolling <b>180-day TTL</b> [TO CONFIRM]. Auto-reply reads live thread + Event Brief data in place (no separate store beyond the chat system, DPS-07)                                                                                                                                                                                                                                                                                                                                                         |
| <b>Security measures</b>           | Per-vendor single-tenant isolation; both capabilities <b>fail-closed</b> until DPO-activated on the <code>/admin/data-privacy</code> control board; "■ AI auto-reply" transparency label; SPI / face / guest-list carve-out enforced in code; TLS 1.3; AES-256                                                                                                                                                                                                                                                                                                |
| <b>Risk level</b>                  | <b>Medium</b> — automated processing (§34) of couple message content + AI web-research that may store incidental third-party PII. Public Privacy Policy §"Vendor AI assistant" + §"Vendor Deep Search" disclosures <b>LIVE</b> ; the <code>/admin/data-privacy</code> controls hold both OFF until DPO sign-off; retention rule + LIA finalization outstanding                                                                                                                                                                                                |

## DPS-14 · Coordinator Delegated Access — consent scopes + prep-then-release (0021)

| Field | Detail |
|-------|--------|
|-------|--------|

|                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Purpose</b>                     | Let a couple delegate planning access to a <b>coordinator</b> they invite (a planner / family / friend — host-side, not Setnayan staff). At invite the coordinator accepts an RA 10173 <b>consent modal</b> scoping access to the couple's <b>guest list, seating, schedule, and vendor chats</b> . The couple may optionally grant <b>"Can finalize vendors"</b> and <b>"Can handle payments"</b> scopes (lock vendors + complete an apply-then-pay checkout on the couple's behalf). <b>Prep-then-release</b> lets the coordinator stage run-of-show/schedule blocks privately and release them to the couple (staged blocks hidden from couple/guests/vendors until released). Gated behind the <code>/admin/data-privacy</code> controls <code>coordinator_consent_money</code> + <code>coordinator_prep_release</code> (fail-closed) |
| <b>Legal basis</b>                 | <b>Consent (§12(a))</b> captured on the invite modal + <b>Contract (§12(b))</b> — service delivery. Money scopes are <b>opt-in by the couple</b> ; consistent with the platform-wide rule that <b>Setnayan never holds, moves, or records the transfer of any money</b> (the coordinator prepares the same off-platform payment; settlement is direct couple↔vendor)                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| <b>Data subjects</b>               | Couples (planning data + optional money authority delegated) + guests (whose PII the coordinator sees within scope) + coordinators                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| <b>Personal data categories</b>    | Guest list + RSVP data, seating, schedule / run-of-show, vendor chat threads — scoped to the granted permissions; optional money-adjacent actions (vendor finalize, checkout) when the couple grants the scope; staged prep-release schedule blocks (hidden until released). <b>Face / biometric data excluded</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| <b>SPI?</b>                        | <b>N</b> — no new SPI collection; scoped delegated access to the couple's existing planning data (incl. guest PII)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| <b>Recipients / sub-processors</b> | Supabase (Postgres, Singapore) — RLS event/thread scoping + per-thread coordinator join permission (see DPS-07). <b>No new sub-processor</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| <b>Cross-border transfer</b>       | SG (Supabase)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| <b>Retention</b>                   | Follows the parent event data (DPS-01 / DPS-03 / DPS-07) — 5 years post-event. Coordinator access is <b>revocable by the couple</b> at any time; revocation removes access prospectively                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| <b>Security measures</b>           | RLS event/thread scoping; consent captured at invite (durable proof); money scopes opt-in <b>and</b> separately gated; face/biometric excluded; staged prep-release hidden until released; controls <b>fail-closed</b> until DPO-activated; TLS 1.3; AES-256                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| <b>Risk level</b>                  | <b>Medium</b> — widens a coordinator's access over guest PII and, if the couple grants it, money-adjacent actions. Public Privacy Policy §"Coordinators you invite" disclosure <b>LIVE</b> ; confirm the DPO ruling before activating the <code>coordinator_consent_money</code> control                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |

## DPS-15 · Guest-Written Columns — guest-authored text published to the open web (2026-08-02)

| Field                       | Detail                                                                                                                                                                                                                                                                                                                                                            |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Purpose                     | Let a guest write one short column (title + body) for the couple's event page. After the couple approves it, the column is <b>published on the open web</b> on the public event page and may carry into the post-event editorial, under a byline drawn from the guest-list name                                                                                   |
| Legal basis                 | <b>Consent (§12(a))</b> — captured at submit time and stored as a durable timestamp ( <code>consent_captured_at</code> , NOT NULL backstop); publication additionally requires the couple's approval. Withdrawal is self-serve and immediate                                                                                                                      |
| Data subjects               | Guests (authors); persons named inside a guest's free text (incidental)                                                                                                                                                                                                                                                                                           |
| Personal data categories    | Guest-authored free text (title ≤60 chars, body ≤280 chars) + the author's <b>byline</b> (their name as it appears on the event's guest list). No contact details are published                                                                                                                                                                                   |
| SPI?                        | <b>N by design, but elevated</b> — free text is unbounded in content and a guest may volunteer health, religious or political statements about themselves or others. Tier-1 automatic screening runs on every submit; treat as elevated                                                                                                                           |
| Recipients / sub-processors | <b>The open web</b> (public event page; post-event editorial). Supabase (Postgres, SG) for storage. <b>No new sub-processor</b>                                                                                                                                                                                                                                   |
| Cross-border transfer       | SG (Supabase); the published page is world-readable by nature                                                                                                                                                                                                                                                                                                     |
| Retention                   | Lives with the guest record and the event. <b>Withdrawal by the author removes it from the page immediately</b> ; deleting the guest record or the event removes it with them                                                                                                                                                                                     |
| Security measures           | Two independent gates before any publication (automatic screening <b>and</b> couple approval — nothing auto-publishes); consent timestamp captured at submit so consent is never assumed; self-serve takedown (RA 10173 right to erasure/blocking); capability held <b>fail-closed</b> by the <code>/admin/data-privacy</code> control <code>guest_columns</code> |
| Risk level                  | <b>Medium</b> — publication of a named individual's words to the open web. Public Privacy Policy §"Guest-written columns on an event page" disclosure <b>LIVE</b> (scope, approval gate, byline, withdrawal, consent capture all stated)                                                                                                                          |

## DPS-16 · Papic Shared Pool — event-wide guest media visibility + self-linking (2026-08-02)

| Field   | Detail                                                                                                                                                                                                                                                                                                    |
|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Purpose | When the host opens the shared pool for their event, let <b>every signed-in guest of that same event</b> browse the event's whole capture pool, and let a guest <b>self-link</b> to a photo they appear in ("I'm in this"), which joins that photo to their personal gallery, ZIP download and Story reel |

|                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Legal basis                 | <b>Contract (§12(b))</b> — the capture/delivery service the couple bought; <b>Consent (§12(a))</b> — the guest's capture-time opt-in and the per-photo consent state; the host's per-event toggle ( <code>events.pool_gallery_open</code> , default FALSE) is the additional gate                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Data subjects               | Guests whose likeness appears in the media; guests as viewers; incidental non-account attendees appearing in media                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Personal data categories    | <b>Compressed web copies only</b> of photos and short clips (never the geo-bearing original); <code>manual_pick</code> photo tags created by a guest self-linking                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| SPI?                        | <b>N</b> in the general case (images of persons are personal info, not per-se SPI), but images can incidentally reveal SPI. Treat as elevated — see DPS-05                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Recipients / sub-processors | <b>Other signed-in guests of the SAME event only</b> — never the public, never anyone outside that event, never across events. Cloudflare R2 (web copies, signed-URL), Supabase (tags). <b>No new sub-processor</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Cross-border transfer       | APAC (R2) + SG (Supabase) — unchanged from DPS-05                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Retention                   | Follows DPS-05 — full-resolution ORIGINAL held the later of 6 months from the event's first capture and 3 months after the event ENDS, then <b>replaced by</b> a compressed web copy; the compressed copy is free for 5 years and thereafter a paid option whose price is not set. ■ <b>No photo is ever deleted on a schedule — only its resolution changes. The host's toggle closes the pool retroactively</b> — turning it off withdraws event-wide visibility from media already captured. ■ <b>CORRECTED 2026-08-17.</b> This row was drafted 2026-08-02 and back-referenced DPS-05 as "90 days hot + 5 years IA cold" — the tiering that DPS-05 itself had already retired on 2026-08-07. It was never built, no R2 lifecycle rule exists, and it declared a destruction we do not perform. |
| Security measures           | The pool read is a single RPC that bakes in <b>all three</b> protections: the FaceBlock blur rule, the <code>photo_consent</code> veto, and <b>web-copy-only keys</b> so a geo-bearing original can never be served here; automatic screening must have passed; scoping is per-event and cannot drift; capability held <b>fail-closed</b> by the <code>/admin/data-privacy control papic_pool_gallery</code>                                                                                                                                                                                                                                                                                                                                                                                       |
| Risk level                  | <b>Medium-High</b> — this is the widening from <i>per-guest tagged delivery</i> to <i>event-wide visibility</i> : a guest's shots become visible to every other guest at that celebration. Public Privacy Policy §"Photos and videos — location data and guest capture" discloses the shared pool explicitly (scope, web-copies-only, screening, event-scoping, self-linking, and how to avoid it) — <b>LIVE</b>                                                                                                                                                                                                                                                                                                                                                                                   |

## DPS-17 · Same-Date Demand Signal — cross-couple aggregate (2026-08-02)

| Field | Detail |
|-------|--------|
|-------|--------|

|                                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|-------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Purpose</b>                      | Tell a couple how many <b>other couples have inquired</b> with the same vendor for the <b>same exact date</b> , and feed that number to the "In demand right now" ranking lens as a sub-score                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| <b>Legal basis</b>                  | <b>Legitimate interest (§12(f))</b> — marketplace transparency so a couple can judge urgency on real activity rather than on a scarcity claim. Balancing test rests on the three minimisations below                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| <b>Data subjects</b>                | Customers (couples) — both the couple who sees the number and the couples counted in it                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| <b>Personal data categories</b>     | <b>An aggregate count only.</b> No identity, no event id, no vendor-couple pairing and no date of any other couple leaves the server — the recipient receives an integer                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <b>SPI?</b>                         | <b>N</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <b>Recipients / sub-processors</b>  | The inquiring couple, in-app only. <b>No new sub-processor</b> ; the aggregation is a Postgres read                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| <b>Cross-border transfer</b>        | SG (Supabase)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| <b>Retention</b>                    | <b>None</b> — the count is computed per request and never stored                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| <b>Security measures</b>            | Three minimisations, all server-side: (1) <b>inquiry-only</b> — the count discriminates on <code>chat_threads</code> existence, so a vendor a couple merely <i>saved</i> contributes zero (a save is not competition — owner ruling 2026-06-02); (2) <b>min-3 floor</b> — nothing below <code>MIN_DEMAND_COUPLE_COUNT = 3</code> is returned at all, because <code>n=1</code> on a solo vendor for an exact date in a small municipality is functionally re-identifying; (3) <b>exact-date only</b> , with no month/year fallback, so a couple without a fixed date generates and receives nothing. Capability held <b>fail-closed</b> by the <code>/admin/data-privacy</code> control <code>same_date_demand</code> (seeded <b>inactive</b> ) |
| <b>Residual concern for the DPO</b> | <b>There is no per-couple opt-out.</b> A couple cannot exclude their own inquiry from the counts other couples see. The mitigation is that what is disclosed is an aggregate at or above 3, never an identity — but the absence of an opt-out is the point on which a ruling is asked                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| <b>Risk level</b>                   | <b>Low–Medium</b> — the only cross-couple disclosure on the marketplace, but bounded to an integer $\geq 3$ . Public Privacy Policy §"Vendor interest counts (what other couples can see)" disclosure <b>LIVE</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |

## DPS-18 · Live Video Connections — WebRTC signalling + TURN relay (2026-08-02)

| Field          | Detail                                                                                                                                                                                                                                                                                                                                                  |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Purpose</b> | Carry live audio/video <b>directly between two devices</b> for: voice/video calls inside a vendor conversation; a camera operator's phone feeding the couple's Live Studio control room; a guest tapping a side camera on an event page; and the homepage live demo. Relay the media through a TURN server <b>only</b> when a direct path is impossible |



|                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Legal basis</b>                 | <b>Contract (§12(b))</b> — delivery of the calling / Live Studio features the user initiated                                                                                                                                                                                                                                                                                                                                              |
| <b>Data subjects</b>               | Couples, vendors, coordinators, guests, camera operators — anyone who joins a live connection                                                                                                                                                                                                                                                                                                                                             |
| <b>Personal data categories</b>    | <b>IP addresses</b> , as ICE candidates. A direct connection is only possible if each device learns the other's address; this is inherent to WebRTC everywhere, not something Setnayan adds. Plus a per-connection technical record of <b>whether the path was direct or relayed and the general network type</b>                                                                                                                         |
| <b>SPI?</b>                        | <b>N</b>                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| <b>Recipients / sub-processors</b> | The <b>other participant's device</b> (inherently receives the IP). <b>STUN</b> address discovery: Google or Cloudflare public servers. <b>TURN relay</b> (relayed sessions only). Setnayan's own infrastructure carries the setup messages <b>in transit</b>                                                                                                                                                                             |
| <b>Cross-border transfer</b>       | Yes — STUN/TURN endpoints are outside PH                                                                                                                                                                                                                                                                                                                                                                                                  |
| <b>Retention</b>                   | <b>Addresses are not retained.</b> The candidate addresses pass through the signalling path in transit and are <b>not written to the database, not logged, and not used for anything else</b> . What is kept per connection is direct-vs-relayed + general network path type, for sizing relay cost — that record contains <b>no IP address and no audio or video</b>                                                                     |
| <b>Security measures</b>           | <b>Calls are never recorded</b> (platform lock). Media is end-to-end between the two devices on a direct path; on a relayed path the TURN server forwards encrypted media it cannot read. No content of any call is stored                                                                                                                                                                                                                |
| <b>Risk level</b>                  | <b>Medium</b> — IP exposure between participants is unavoidable for the feature to exist and is disclosed in plain language rather than buried. Public Privacy Policy §"Live video connections (calls and event cameras)" explains the IP exchange, the STUN contact, the in-transit-only signalling, and exactly what is kept — <b>LIVE</b> . <i>(This entry closes the RoPA item owed for WebRTC/TURN — security handoff task #42.)</i> |

## DPS-19 · Coordinator Day-of Operations — filtered run-of-show · announcements · requests desk (2026-08-02)

| Field          | Detail                                                                                                                                                                                                                                                                                                                                                     |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Purpose</b> | The three surfaces a coordinator acts from on the event day, as distinct from the planning-phase delegation in DPS-14: (1) the <b>filtered run-of-show</b> — one master timeline auto-filtered per audience; (2) <b>day-of announcements</b> — a short broadcast to the event; (3) the <b>requests desk</b> — a single inbox of things raised on the floor |

|                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|-----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Why a separate entry        | DPS-14 declares the coordinator's <i>consent scopes</i> and <i>prep-then-release</i> , i.e. what a coordinator may <b>see</b> and stage. It never named these three, and all three are <b>active in production</b> . Two of them are outward actions rather than reads — one of which reaches the couple's <b>guests</b> — so they belong on the register in their own right                                                                                                                                                                   |
| Legal basis                 | <b>Contract (§12(b))</b> — running the event the couple engaged the platform for; <b>Consent (§12(a))</b> — the coordinator's own access consent captured at invite (DPS-14)                                                                                                                                                                                                                                                                                                                                                                   |
| Data subjects               | Couples; guests (as announcement recipients and as the subject of floor requests); vendors (as filtered-timeline recipients and requesters); coordinators                                                                                                                                                                                                                                                                                                                                                                                      |
| Personal data categories    | <b>Run-of-show:</b> schedule blocks + responsible-party tags. <b>Announcements:</b> free text ≤500 chars + the sender's identity and timestamp; immutable once posted. <b>Requests desk:</b> the request's free text + who raised it + its lane/status                                                                                                                                                                                                                                                                                         |
| SPI?                        | <b>N</b> — no new sensitive category. Free text in an announcement or a request is unbounded in principle; both are event-scoped and short-lived                                                                                                                                                                                                                                                                                                                                                                                               |
| Recipients / sub-processors | <b>Announcements are read by everyone on the event</b> — couple, guests and vendors alike (RLS Pattern B member read + delegate read + admin observability). Run-of-show is <i>narrowed</i> per audience: a vendor sees only blocks they are tagged responsible on, a guest sees only public rows, the couple sees the master. Requests stay between the raiser and the coordinator/couple. Supabase (Postgres, SG). <b>No new sub-processor</b>                                                                                               |
| Cross-border transfer       | SG (Supabase)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Retention                   | Follows the parent event — deleted with it (ON DELETE CASCADE), inside the 5-year event-data window                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Security measures           | All three held <b>fail-closed</b> by their own /admin/data-privacy controls (coordinator_run_of_show, coordinator_day_of_broadcast, coordinator_requests_inbox); event-scoped RLS with <b>canonical patterns only</b> ; announcements are <b>immutable and attributed</b> — no silent edit or anonymous post; the run-of-show filter is a genuine <b>minimisation</b> (a vendor cannot read the parts of the day that are not theirs); <b>no acknowledgment tracking</b> was built, so reading an announcement is not recorded against a guest |
| Risk level                  | <b>Low–Medium</b> — the outward reach to guests is the notable part, and it is bounded to a short, attributed, event-scoped message. Public Privacy Policy §"Coordinators you invite (delegated access)" gained both missing paragraphs on 2026-08-02 (announcements + requests desk) — <b>LIVE</b>                                                                                                                                                                                                                                            |

## 2. Threshold analysis — mandatory NPC registration

Under **RA 10173 and NPC Circular 17-01** (as amended), a PIC/PIP must register its DPS and DPO with the NPC when **any** of the following triggers is met. Assessment below.

| # | Registration trigger<br>(Circular 17-01 §4 / related issuances)                         | Setnayan assessment                                                                                                                                                                                                                                                                                                            | Met?              |
|---|-----------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------|
| 1 | Processing <b>sensitive personal information of ≥ 1,000 individuals</b>                 | Setnayan processes SPI: <b>biometric face vectors</b> (DPS-04), <b>government ID + liveness</b> for vendors (DPS-02), and potential <b>health/religious</b> data via RSVP dietary/special needs (DPS-03). Actual count [TO CONFIRM], but a weddings/events platform at scale is very likely to reach ≥1,000 SPI subjects       | <b>Likely YES</b> |
| 2 | PIC/PIP with <b>≥ 250 employees</b>                                                     | Sole proprietorship; headcount [TO CONFIRM] but almost certainly <b>&lt; 250</b>                                                                                                                                                                                                                                               | No (assumed)      |
| 3 | Processing is <b>likely to pose a risk to the rights and freedoms</b> of data subjects  | Yes — biometric processing, gov-ID + AML screening, guest likeness/media at scale, relationship graph, minors/legacy roadmap, <b>and (DPS-12) involuntary identity-profiling with an automated decision that has a significant effect (auto-suspend/ban of a vendor's livelihood)</b> . This is high-risk processing by nature | <b>YES</b>        |
| 4 | Processing is <b>not occasional</b> (i.e., regular/systematic core-business processing) | Yes — data processing is the platform's core, continuous business function, not incidental                                                                                                                                                                                                                                     | <b>YES</b>        |

**Conclusion.** Registration triggers **#1 (likely), #3, and #4 are met**. Trigger #2 is not (sole prop, sub-250 headcount). Under Circular 17-01 the criteria are **disjunctive** — meeting even one obligates registration, and Setnayan meets at least two independently (risk-to-rights + not-occasional), with the SPI-volume trigger also likely once counts are confirmed.

**Recommendation:** Setnayan should register its DPO and Data Processing Systems with the National Privacy Commission (NPC registration system), and appoint/confirm Indalecio Sacdalan Casasola II as the registered DPO. Registration is advisable on the risk-to-rights and not-occasional grounds alone; the SPI-volume trigger reinforces it. Confirm exact SPI data-subject counts [TO CONFIRM] and current NPC registration number [TO CONFIRM] before filing to determine whether this is an initial registration or an amendment.

### 3. Open items for DPO/counsel before filing

- [TO CONFIRM] Registered business address; headcount; SPI + total data-subject counts; existing NPC registration number.
- [TO CONFIRM] Exact RSVP special-data fields (dietary/health/religious) — determines whether DPS-03 is a formal SPI system.
- [TO CONFIRM] Jurisdictions/retention for Resend, PostHog (analytics), Vercel edge, Suno, and the face-matching engine host.
- [TO CONFIRM] Whether Maya Business (V1.5 payment gateway) is contracted; keep DPS-08 marked "not active" until then.
- DPS-06 (Person Graph) and the Person Graph amendment publish **only after** DPO/counsel sign-off; minors/legacy (Phase 3) require their own DPIA + NPC consultation before any build-to-live.
- DPS-13 (Vendor AI) and DPS-14 (Coordinator Delegated Access) are each held **fail-closed** by the in-app /admin/data-privacy control board; confirm the DPO ruling + finalize the Deep Search retention rule (180-day) before activating the corresponding controls. [TO CONFIRM]

---

*Draft compliance artifact prepared to a compliant baseline ahead of counsel. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel; this document is not a substitute for legal review and is not yet adopted for NPC filing.*